Note de cadrage, Operation Gryphon

Nov 4, 2026 · @Marc BOHOUSSOU

Campagne Red Team contre le domaine Active Directory `meridian.local` de la banque fictive Meridian : monter la cible, l'attaquer de l'acces initial a la domination du domaine, puis analyser ses propres traces pour en deduire des detections.

Contexte et objectif

Meridian est une banque fictive dont le systeme d'information repose sur un domaine Active Directory. Le mandat simule une intrusion interne : un attaquant disposant d'un acces utilisateur standard cherche a prendre le controle complet du domaine et a exfiltrer des donnees sensibles.

L'objectif pedagogique est double. D'abord demontrer la chaine d'attaque offensive de bout en bout, de l'acces initial a la domination du domaine. Ensuite, et c'est la vraie valeur ajoutee, exploiter les traces laissees par l'attaque pour construire une capacite de detection (matrice ATT&CK annotee et regles Sigma).

Le projet est realise en solo. L'ensemble du montage et de l'attaque doit etre reproductible a l'identique depuis un depot Git.

Perimetre

Dans le perimetre : le montage d'un domaine Active Directory mono-domaine (`meridian.local`), son attaque complete depuis un compte standard compromis, et l'analyse defensive differee des journaux produits.

Hors perimetre : toute architecture multi-domaine ou multi-foret, les postes clients du domaine (couche 2) et le contournement d'un EDR (couche 3), qui sont decrits en theorie dans le rapport mais non demontres. Aucune action destructrice n'est menee : les comptes et donnees ne sont pas supprimes, les seules donnees manipulees sont fictives.

Palier technique retenu et justification

Palier retenu : le socle (contrôleur de domaine seul). Ce palier valide les compétences visées ; les couches 2 et 3 sont traitées en théorie.

La configuration de référence du sujet (Windows Server 2025 Datacenter, évaluation 180 jours, x86-64, virtualisé en local) n'a pas pu être tenue sur le matériel disponible. Deux postes locaux se sont révélés inexploitables : un portable ARM64, sur lequel aucun

Windows Server x86 ne tourne nativement, et un poste i7 au disque défaillant. L'émulation QEMU x86 sur l'hôte ARM a été testée mais s'est avérée trop lente pour l'installation d'Active Directory.

Écart assumé : le contrôleur de domaine est hébergé sur une machine virtuelle cloud (Google Cloud Platform), avec l'image officielle Windows Server 2025 Datacenter. L'attaque est menée depuis un poste Kali local. L'accès à la VM est restreint par pare-feu à la seule adresse IP de l'attaquant. Cet écart et les alternatives écartées sont détaillés en annexe du rapport.

Hypothèses et règles d'engagement

- Accès initial simulé : un compte utilisateur standard (`jdupont`) est considéré comme compromis, mot de passe obtenu hors périmètre. Il n'y a pas de phase de phishing réel.
- Chemins d'attaque volontaires : le domaine est monté avec des faiblesses délibérées et documentées (compte de service avec SPN et mot de passe faible, compte sans pré-authentification Kerberos), pour que l'escalade ait prise.
- Aucune destruction : la persistance (Golden Ticket, comptes de backdoor) peut être démontrée mais ne doit rien casser.
- Données fictives uniquement : le partage cible ne contient que de faux relevés.
- Reproductibilité : chaque commande de montage et d'attaque est horodatée dans le journal temps réel et rejouable depuis le dépôt Git. Aucun secret réel (mot de passe, hash) n'est stocké en clair dans le dépôt.

Scénario d'attaque

La campagne suit une kill chain en sept étapes, chacune rattachée à une technique MITRE ATT&CK.

Phase	Tactique	Technique	Action
1	Discovery	T1087.002	Reconnaissance du domaine et énumération des comptes
2	Credential Access	T1558.003	Kerberoasting du compte de service svc_sql
3	Credential Access	T1110.002	Crackage hors ligne du mot de passe
4	Privilege Escalation	T1078.002	Usage du compte svc_sql, Domain Admin
5	Credential Access	T1003.006	DCSync, réplication des secrets du domaine

Phase	Tactique	Technique	Action
6	Lateral Movement	T1550.002	Pass-the-Hash du compte Administrator
7	Collection / Exfiltration	T1039	Exfiltration des données du partage cible

Le compte AS-REP roastable (`mservice`) constitue un chemin secondaire. La persistance par Golden Ticket (T1558.001), rendue possible par le vol du hash krbtgt en phase 5, reste optionnelle.

Livrables

- Note de cadrage (ce document).
- Journal temps réel : CSV horodaté, une ligne par action, avec technique ATT&CK et trace attendue.
- Note de montage du lab : architecture, scripts de déploiement du domaine, chemins d'attaque posés.
- Matrice ATT&CK annotée : techniques jouées et couverture de détection.
- Règles Sigma : rejouées hors ligne sur les journaux exportés du contrôleur de domaine.
- Rapport final : déroulé de l'attaque, analyse défensive, recommandations, annexe de justification technique.

L'ensemble est versionné dans un dépôt Git, hors secrets réels.

Jalons des 5 jours

Jour	Phase	Livrable attendu
J1	Cadrage et montage du lab	Note de cadrage, domaine monte, chemins d'attaque poses
J2	Attaque, acces initial a l'escalade	Reconnaissance, Kerberoasting, crack, escalade journalises
J3	Attaque, domination et exfiltration	DCSync, Pass-the-Hash, exfiltration journalises
J4	Analyse defensive	Sysmon, export des journaux, rejeu Sigma, matrice ATT&CK

Jour	Phase	Livrable attendu
J5	Consolidation	Rapport final, recommandations, depot Git complet

Le planning est indicatif sur une charge de 35 heures. En raison du parcours materiel, le montage et l'attaque ont ete concentres, ce qui laisse une marge pour l'analyse defensive et la redaction.